NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

CS437 Assignment 1

In this assignment, you are asked to implement vulnerable and patched projects that can demonstrate given vulnerabilities/misconfigurations and/or protection mechanisms. You will containerize your application using Docker and prepare a detailed report outlining how these vulnerabilities can be exploited, providing a hands-on approach to learning secure coding practices.

In this assignment, you will be working in a group environment. **Please note that each responsibility can only be taken by only 2 groups. Each group can only select one task. If a responsibility is already taken by 2 groups in the excel sheet, please pick another one.** Each group must contain exactly 3 people. If you are unable to find one, you will be randomly assigned to a group.

Please take a look at Table 1 to find responsibilities to implement with your group members. Vulnerability and protection mechanisms for each group can be found below. **All the example code will be written in *PHP*.** We advise you to use the 8.0.30 *version*. No other programming language is allowed! Do not use React or VueJS to improve the GUI. HTML and CSS can be used to improve the GUI.

Some general rules:

- If you miss the demonstration, you will get 0.
- In the case of a missing report or the code, you will also get 0.
- The report must be very clear. You can lose points due to lack of clarity.
- The code must contain comments! Also, there must be comments explaining the vulnerable and protection lines.
- In the case of **cheating among groups**, both groups will get 0.
- You need to provide a Dockerfile, docker-compose.yml file for us to run and evaluate your assignment, the application that cannot be deployed in TA's computer will get a remarkable point deduction. You make sure to run your application on different computers before submitting your assignment.
- As some of the applications require data in its database, please make sure to include the corresponding sql files to share the data. (i.e. we should be able to import your data via "mysqldump" command in case a mysql database is used.
- You need to comment and explain on the part of the code where you show the vulnerabilities.

```php
<?php
// Input from user (potentially malicious)
$username = $_GET['username'];
$password = $_GET['password'];
/*
VULNERABILITY:
This query directly includes user-provided inputs ($username and $password) without proper
sanitization or parameterization which leads to SQLi vulnerability.
*/
$sql = "SELECT * FROM users WHERE username = '$username' AND password = '$password'";
// Execute the query
$result = $conn->query($sql);
?>
```

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

Exploitation:

The second step of the assignment is to exploit the vulnerabilities that you implemented in your web application. The output of this step includes a video demonstration and a pdf report. Please follow the instructions below to complete this part of the assignment.

- You are required to create a separate video demonstration for each vulnerability and submit the video with a name corresponding to the demonstrated vulnerability.
- You need to show the exploitation clearly in your video.
- The vulnerabilities that could not be exploited will be counted as not implemented so make sure you are able to exploit your implemented vulnerabilities.

Reporting

In the last part of the assignment, you are expected to generate two reports (One of them txt and the other one is pdf). The report needs to be written according to the following instructions. The submission without a report will get 0 automatically. You must generate your report in the specified format. Reports that do not adhere to the given format will incur point deductions.

For the txt report :

An example report (**The report should be a txt file**):

Please see the explanation for the above fields:

-
- **Name (For each single vulnerability) :** Is the field that you need to write the commonly known name of the vulnerability.
- **Category(For each single vulnerability) :** is the field that is known category of the vulnerability according to OWASP TOP-10 2021
- **Technical Explanation (For each single vulnerability):** is the explanation where you deep dive into the vulnerability explanation. This fields may include phrases like: The user input fed directly into the <function_name> function. <function_name> does not have a built-in prevention for this type of input, as a result a user input containing “yyyy” leads to “zzzz”.
- **Exploit (For each single vulnerability):** The payload or method used.

For the pdf report:

The same as a txt report with explanation on screenshots of the vulnerable code and patched code. Moreover, report should contain the link to the video. Lastly, your report should include a table that specifies shared responsibilities among team members if there is any. Basically explaining who did what part.

Table 1: Code defects to pick (responsibilities) and their explanations.

Resp. ID	Explanation
1	**Task 1 : Ukrainian news website** In this task you are asked to create a fully functioning Ukrainian news website that can have unique content. The GUI of the website is important. You are asked to create member login and admin login. Members can post comments to the

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

	news. Meanwhile, admins can add and remove comments and users. News will be changed dynamically which means you do not have to have a functionality in the admin panel to change news, all news will be changed periodically in an automated manner. Password data must be safely stored on the database with a **strong hashing algorithm** and **good salting mechanism**. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Reflected XSS(tag attributes) DOM-Based CWE-35 Path Traversal: '.../...//' SSRF with 2 different PHP function (2 different pages) CWE-434 Unrestricted Upload of File with Dangerous Type Each vulnerability must be implemented on a different php page. CWE-692: Incomplete Denylist to Cross-Site Scripting **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
2	**Task 2 : Russian news website** In this task, you are asked to create a fully functioning website that can present Russian News. The GUI of the website is important. This website should be able to display recent news which is coming from real Russian websites. You can use RSS feeds coming from the Russian news agent. Make sure that your website can offer dynamic content. Users should be able to search for different news. Site can be in English or Russian language. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Reflected XSS (between HTML tags) SQL Injection(1) SQL Injection(2) CWE-35 Path Traversal: '.../...//' File path traversal, traversal sequences stripped non-recursively. SSRF with blacklist-based input filter CWE-434 Unrestricted Upload of File with Dangerous Type (Blacklisting bad prevention) Blind OS Command Injection Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one).

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

	Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
3	**Task 3 : Turkish financial news website** In this task, you are asked to create a fully functioning website that can present Turkish News. The GUI of the website is important. This website should be able to display recent news which is coming from real Turkish websites. You can use RSS feeds coming from the Turkish news agent. Make sure that your website can offer dynamic content. Users should be able to search for different news. Site can be in English or Turkish language. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Stored XSS (between tag attributes) SQL Injection with weak protection(1) SQL Injection with weak protection(2) CWE-863: Incorrect Authorization SSRF with 2 different PHP function CWE-434 Unrestricted Upload of File with Dangerous Type CWE-35 Path Traversal: '.../...//' File path traversal, traversal sequences stripped non-recursively. Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
4	**Task 4 : Turkish travel advice website** You are asked to create a Turkish travel advice website. This website should be able to display recent news about travel restrictions which are coming from real websites. You can use RSS feeds coming from travel advice agents or newspaper websites. Make sure that your website can offer dynamic content. Users should be able to search for different news. Site can be in English or Turkish. Moreover, you are asked to create member login and admin login. Members can post comments to the news. Meanwhile, admins can add and remove comments and users. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Stored XSS (between HTML tags) CWE-692: Incomplete Denylist to Cross-Site Scripting CWE-862: Missing Authorization SSRF with blacklist-based input filter CWE-434 Unrestricted Upload of File with Dangerous Type (Blacklisting bad prevention)

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

	CWE-312: Cleartext Storage of Sensitive Information Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
5	**Task 5 : Azerbaijan News website** You are asked to create a Azerbaijan news website. This website should be able to display recent news which is coming from real Azerbaijan news websites. You can use RSS feeds coming from the Azerbaijan news agent. Make sure that your website can offer dynamic. Users should be able to search for different news. Site can be in Azerbaijani. News will be changed dynamically. There will be both user and admin side. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Reflected XSS (tag attributes) (1) Reflected XSS (tag attributes) (2) CWE-78: Improper Neutralization of Special Elements in OS Command CWE-601: URL Redirection to Untrusted Site ('Open Redirect') SSRF with 2 different PHP function CWE-209 Generation of Error Message Containing Sensitive Information CWE-95: Improper Neutralization of Directives ('Eval Injection') Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
6	**Task 6 : Turkish University advice website** You are asked to create a Turkish University advice website. This website should be able to display recent news or ranking information which is coming from real Turkish websites. You can use RSS feeds coming from the Turkish news agencies or other websites. Make sure that your website can offer dynamic content. Users should be able to search for different news. Site can be in English or Turkish. There should be admin and user side. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Reflected XSS (between HTML tags) Blind OS Command Injection (1) Blind OS Command Injection (2) CWE-352: Cross-Site Request Forgery (CSRF) SSRF with blacklist-based input filter CWE-434 Unrestricted Upload of File with Dangerous Type CWE-35 Path Traversal: '.../...//'

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

	Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
7	**Task 7 : Turkish news** You are asked to create a Turkish news website. This website should be able to display recent news which is coming from real Turkish news websites. You can use RSS feeds coming from the Turkish news agent. Make sure that your website can offer dynamic content. Users should be able to search for different news. Site can be in English or Turkish. We would like to see daily news coming from this website. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Stored XSS (between tag attributes) CWE-502: Deserialization of Untrusted Data (PHP Object Injection) CWE-540: Inclusion of Sensitive Information in Source Code SSRF with 2 different PHP function CWE-434 Unrestricted Upload of File with Dangerous Type (Blacklisting bad prevention) Reflected XSS (tag attributes) Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
8	**Task 8 : English Cryptocurrency News website** In this task, you are asked to create a fully functioning website that can present Cryptocurrency news & values (Prices in USD and TL) website in English. The GUI of the website is important. This website should be able to display recent news which is coming from real websites. You can use RSS feeds coming from the newsagent. You can also use data coming from API feeds from cryptocurrency APIs. You can periodically collect data and present the results. For instance, website can present daily dogecoins value and a comparison with other coins. Make sure that your website can offer dynamic content. Users should be able to search for different news. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: Stored XSS (between HTML tags) CWE-95: Improper Neutralization of Directives ('Eval Injection') CWE-863: Incorrect Authorization SSRF with blacklist-based input filter(1) SSRF with blacklist-based input filter (2)

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

	CWE-312: Cleartext Storage of Sensitive Information Reflected XSS (between HTML tags) Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
9	**Task 9 : Global News website** In this task you are asked to create a fully functioning Global News website that can have unique content. You are asked to create a global news website. This website should be able to display recent news which is coming from the real global news. You can use RSS feeds coming from the global news agents. Users should be able to search for different news. Website news should be in English. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: DOM-Based SQL Injection (1) SQL Injection (2) SSRF with blacklist-based input filter(1) CWE-862: Missing Authorization SSRF with 2 different PHP function CWE-209 Generation of Error Message Containing Sensitive Information CWE-502: Deserialization of Untrusted Data (PHP Object Injection) Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.
10	**Task 10 : Turkish Cryptocurrency News website** In this task, you are asked to create a fully functioning website that can present Cryptocurrency news & values (Prices in USD and TL) website in Turkish. The GUI of the website is important. This website should be able to display recent news which is coming from real Turkish websites. You can use RSS feeds coming from the newsagent. You can also use data coming from API feeds from cryptocurrency APIs. You can periodically collect data and present the results. For instance, website can present daily dogecoins value and a comparison with other coins. Make sure that your website can offer dynamic content. Users should be able to search for different news. **You can add other functionality and other pages to accommodate vulnerabilities assigned to you. Use your creativity.** **Vulnerability:** You are asked to implement following vulnerabilities: SQL Injection with weak protection(1) SQL Injection with weak protection(2)

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.

	CWE-78: Improper Neutralization of Special Elements in OS Command CWE-601: URL Redirection to Untrusted Site ('Open Redirect') SSRF with blacklist-based input filter CWE-434 Unrestricted Upload of File with Dangerous Type SSRF with blacklist-based input filter Each vulnerability must be implemented on a different php page. **Protection**: Same application without these vulnerabilities (Patched one). Patched version must be another dockerized project. Both vulnerable and patched versions' source codes must be provided.

Part 0: Form a group and fill the spreadsheet

To begin the project, form a group (of three), pick a responsibility and fill your information in the following spreadsheet:

2024 CS 437 Assignment 1 Groups 2024

What needs to be submitted :

1. Video of the exploitation and patching
    a. Link could be included in pdf report
    b. Explain the application, exploit the vulnerability and vulnerable code
    c. Explain the patching and patched code
2. Txt report as described above
    a. Above a detailed version is provided
3. Pdf report as described above
    a. Explain the vulnerable and patched code with screenshots
    b. Remark: report should contain the link to the video
    c. ***Sources/ reference (Weblink, book, magazine or github repo) used to write the code.***
    d. Your report should include a table that specifies shared responsibilities among team members if there is any. Basically explaining who did what part.
4. Source code of vulnerable and patched code
    a. Feed the code with malicious inputs or bypass mechanisms to demonstrate the vulnerability or protection mechanism.
    b. If a database is created, also explain how this database has been created and populated!
5. Dockerized vulnerable project and patched project

Moreover, after the deadline you will have another demonstration with the teaching assistant. We will provide more information about this later on.

Each group member should submit the same work!!

NOTE: THIS MATERIAL IS A PROPERTY OF SABANCI UNIVERSITY. ANY UNAUTHORIZED USE OR DISTRIBUTION IS STRICTLY PROHIBITED.